

Literature Review

Aayuman Ghangurde
Purdue University

Sai Palaparthi
Purdue University

Rakib Ahsan
Purdue University

Zeke Ulrich
Purdue University

1 Related Work

1.1 Technical Report on a Virtual CTAP2 WebAuthn Authenticator [3]

This technical report covers the development of the associated open source Virtual CTAP2 WebAuthn authenticator. In addition to a software only authenticator it also provides a proof of concept implementation of a Trusted Platform Module (TPM) based authenticator, with associated interfaces and libraries for using a TPM as the underlying credential store. This project wants several improvements we hope to make. First, the authors deliberately keep client-PIN verification outside the TPM, reasoning that the PIN is typed anyway so it "doesn't warrant" TPM protection. This is a waste of modern TPMs' built-in dictionary-attack prevention, which we can enable. Second, their authenticator uses a flat key hierarchy with no dictionary-attack protection on the intermediate key. If we use passkey signing keys as children of an intermediate PIN key that has a lockout policy, then unlocking the PIN key makes them usable just as with Windows Hello and we have brute force protection against the PIN. Third, the paper notes that their method of emulating a USB HID device is fragile. We can build the authenticator as a PAM module for extensibility. Finally, the authenticator supports only ES256, which we could expand to RSA and Ed25519.

1.2 Securing FIDO2 Credentials Using Intel SGX [10]

This paper builds a centralized, replicated FIDO2 credential manager similar to the one we're building, using /dev/uhid to emulate a USB HID FIDO2 device like tpm-fido/VirtualWebAuthn does. Their conclusion states they want to "improve the Authenticator Emulator to use a local vault (e.g., TPM-based) to store a UID protected by a secret or biometrics" just as we're doing. In fact, Intel has discontinued SGX so the credential manager must be migrated to a TPM anyway.

1.3 Formal Analysis of the TPM and FIDO

The Fast IDentity Online (FIDO) framework consists of two specifications: Universal Authentication Framework (UAF) and Universal 2nd Factor (U2F). For this project, we will be focusing on using UAF as a way to log into a Linux system with a TPM acting like the FIDO authenticator. According to Haonan Feng et al. [5], the base standard for UAF is defined with an extremely strong security model, to the point of being impractical, so most implementations do not follow the standard strictly.

When analyzed under a more realistic scenario, there are some practically viable vulnerabilities in the protocol that can be exploited. One example of such an attack is a transaction tampering attack [5], which the paper did not provide a solution to. However, according to Shao et al. [15], the TPM supports using HMAC to encrypt and validate communication between itself and the CPU which could be a viable solution to this particular type of attack. Analysis of the security of the HMAC authorization mechanism in the paper reveals that the implementation is sufficiently secure under most conditions [15] and therefore gives us a base for designing our threat model.

In another study by Bindel, et. al [2] the authors formally analyze FIDO2's security with the CTAP 2.1 and WebAuthn 2 sub-protocols. The authors prove post-quantum security for FIDO2 under certain conditions and minor protocol extensions, and show a simple improvement for the downgrade resilience of FIDO2. Since the paper is an abstract proof of CTAP and WebAuthn, the authors do not model some of the new CTAP 2.1 features for enterprise customers, and do not make formal statements about the unlinkability of credentials or other detailed privacy statements. Thus, the implementation of these standards may have unaddressed vulnerabilities.

1.4 TPM-Attest: Hardware-Rooted Integrity Attestation as a Kernel-Level Anti-Cheat Alternative for Linux [6]

While the main focus of this paper is leveraging hardware backed boot verification as an anti-cheat for video games on Linux, the concepts discussed can be applied to any traditional secure boot setup because both of these applications have the same goal: To stop unauthorized and unverified code from executing at boot. This paper proposes using the Linux Integrity Measurement Architecture (IMA) alongside the TPM to gather all the information needed to validate the kernel that is currently running. One thing this paper fails to include is being able to stop the kernel if an error is detected in integrity measurement, or ideally, a self-healing procedure if integrity is compromised. While we can use this as a base for verified boot, we would have to combine this idea with something like dm-verity in Linux to make this a complete solution.

1.5 Attacks against FIDO authenticators

Windows Hello is Microsoft's implementation of the Fast Identity Online (FIDO) protocol. Kim et. al [8] and Lee et. al [9] analyze the architecture of Windows Hello. Lee et. al model an adversary that only has temporary but physical access to the device under malicious (theft) or otherwise benign (repair) conditions. Firstly, Windows 11's transition to TPM is lazy - that is, though required by the OS, the TPM may not actually be utilized to store secrets, which may violate application assumptions allow credential extraction. In addition, biometrics, even with a secure transport layer with the biometric chip, are shown to be vulnerable when the biometric details are stored without proper authentication codes. Kim et al. discuss the architecture of signing onto Windows, especially with online Microsoft-linked accounts, detailing the key derivations and decryption steps from PIN to decryption of user secrets in Windows. Kim et al. specifically do not consider the TPM, and one of their key attacks centers around brute-forcing the user's PIN.

Trust Dies in Darkness [14] by Shakevsky et. al details the architecture of Samsung's TrustZone Keymaster. Samsung implements a two-pronged solution in which a secure world and a normal world are kept separate by a secure monitor. The authors discovered certain devices were vulnerable to downgrade attacks. The possibility of a downgrade attack should be modeled and addressed in any implementation. In the TrustZone architecture, each key blob stored in KeyMaster was derived from hardware-bound master key salted by the application identifiers and other constants using AES-GCM. The hardware security module was controlled by the secure world. However, an endpoint was incorrectly exposed to the normal world which allowed access to encryption with the master-key AES-GCM cipher, while also allowing specifying the IV (the salt). Thus, an IV reuse attack could be used,

breaking the AES-GCM cipher. This could then allow FIDO passkeys to be copied from the secure chip. We learn from this paper that access to the TPM should be carefully exposed and well-guarded.

1.6 Adoption, Implementation and Usage of Passkeys

Farke et. al [4] is an early study (relative to passkeys) from 2021 that investigates the deployment in a small business, and employees' sentiments on the adoption of Biometric and PIN-based authentication. Windows Hello for Business was used as the platform. It finds that users prefer the shorter PIN's, and the overall experience (including biometrics) was perceived as quicker. The participants in the study expressed some doubts that biometric data could leave the machine. One of the key findings of this early study was that Windows Hello passkeys were resident (bound) to the device - they could not roam like physical keys - and were thus unsuitable for shared computers. Reitinger and Pernul [12] publish a more modern 2026 study, in a diverse passkey environment as implementations evolved over time. They investigate the challenges in adoption and use of passkeys, finding that users still perceive passkeys superior to passwords. Reitinger and Pernul recommend a dedicated passkey management UI and clarity in where passkeys are stored (e.g. cloud-backed v.s bound to device)

In The State of Passkeys: Studying the Adoption and Security of Passkeys on the Web [7] the authors perform a comprehensive security evaluation of passkey implementation in websites. The authors identify lack of standardization and serious security issues in a majority of websites, including use of deprecated cryptographic algorithms and critical or high CVSS scores. The authors present PASSKEYS-RADAR for tracking deployment of passkeys on the web, and PASSKEYS-ATTACKER for exploiting security vulnerabilities on insecure sites.

Though these studies are relatively diverse, they have a recurring theme: transparency. In the one case, Windows Hello technology can choose to not use TPM-backed security without indication. In the other, whether passkeys are synchronized to the cloud or local-only is confusing. We must consider a design that is explicit about the capabilities of the passkeys it stores, and furthermore, can denote it remains on a older security standard should future security protocols become standardized. Finally, we note that users, generally, have positive sentiments towards passkeys, both in PIN and biometric forms, as well as in actual use: continuing to bring better passkey support to Linux is not a fruitless endeavour.

1.7 TPM in Verified/Measured Boot

Arbaugh et al. first introduced the "chain of trust" idea for booting a computer [1]. Their core argument was to securely verify the integrity of the next layer before handing over control, and code execution halts with a recovery mechanism

in case of an integrity check failure. This has evolved into modern-day Secure/Verified Boot. While Secure Boot blocks the execution of an untrusted layer, Sailer et al. proposed an alternative: measuring every loading step from boot loader to application layer inside TPM-protected logs, so that it can be verified later through TPM-backed attestation. This is known as Measured/Trusted Boot [13]. Parno et al. [11] draw a contrast between these two schemes and discuss how Trusted Computing is put to practical use, such as sealing secrets in a trusted boot state, like in BitLocker, as well as letting a verifier remotely check a device’s log through TPM attestation.

A recent use case was introduced by Woltjen et al. on the Raspberry Pi [16]. They identified that the Raspberry Pi has only the capability for Secure Boot, but not Measured Boot due to the absence of TPM driver support. The authors addressed this limitation by integrating U-Boot into the Raspberry Pi to connect with TPM 2.0, and thus combining both Secure and Measured Boot to enable Remote Attestation on the platform.

References

- [1] William A Arbaugh, David J Farber, and Jonathan M Smith. A secure and reliable bootstrap architecture. In *Proceedings. 1997 IEEE Symposium on Security and Privacy (Cat. No. 97CB36097)*, pages 65–71. IEEE, 1997.
- [2] Nina Bindel, Cas Cremers, and Mang Zhao. FIDO2, CTAP 2.1, and WebAuthn 2: Provable security and post-quantum instantiation. In *2023 IEEE Symposium on Security and Privacy (SP)*, pages 1471–1490. IEEE, 2023. Also available as Cryptology ePrint Archive, Paper 2022/1029: <https://eprint.iacr.org/2022/1029>.
- [3] Chris Culnane, Christopher J. P. Newton, and Helen Treharne. Technical report on a virtual CTAP2 WebAuthn authenticator, 2021. 28 pages, 3 figures, Open Source code repository: <https://github.com/UoS-SCCS/VirtualWebAuthn>.
- [4] Florian M. Farke, Leona Lassak, Jannis Pinter, and Markus Dürmuth. Exploring user authentication with windows hello in a small business environment. In *Eighteenth Symposium on Usable Privacy and Security (SOUPS 2022)*, pages 523–540, Boston, MA, August 2022. USENIX Association.
- [5] Haonan Feng, Jingjing Guan, Hui Li, Xuesong Pan, and Ziming Zhao. Fido gets verified: A formal analysis of the universal authentication framework protocol. *IEEE Transactions on Dependable and Secure Computing*, 20(5):4291–4310, 2023.
- [6] Anudeep Gedela and A. Yaswanth. Tpm-attest: Hardware-rooted integrity attestation as a kernel-level anti-cheat alternative for linux, 2026.
- [7] Louis Jannett, Andreas Mayer, Maximilian Westers, Vladislav Mladenov, Christian Mainka, and Jörg Schwenk. The state of passkeys: Studying the adoption and security of passkeys on the web. In *35th USENIX Security Symposium (USENIX Security 26)*, pages 5039–5058, Baltimore, MD, August 2026. USENIX Association.
- [8] Ejin Kim and Hyoung-Kee Choi. Security analysis and bypass user authentication bound to device of windows hello in the wild. *Security and Communication Networks*, 2021(1):6245306, 2021.
- [9] Jeongho Lee, Minkyong Kang, Seunghwan Lee, and Hyoung-Kee Choi. False promises of passwordless: Defeating windows hello through tpm misuses. In *2025 IEEE Annual Computer Security Applications Conference (ACSAC)*, pages 308–321, 2025.
- [10] Tomás Matos, Andre Zuquete, and Tomás Silva. Securing fido2 credentials using intel sgx. In *Proceedings of CYBERSEC 2026: The First International Conference on Security and Cybersecurity in the AI and Digital Context*, Porto, Portugal, 2026. DTR Society Press.
- [11] Bryan Parno, Jonathan M McCune, and Adrian Perrig. Bootstrapping trust in commodity computers. In *2010 IEEE Symposium on Security and Privacy*, pages 414–429. IEEE, 2010.
- [12] Tobias Reitinger and Gunther Pernul. No Password, No Problem? A Large-Scale Field Study of Passkey Adoption and Usage . In *2026 IEEE Symposium on Security and Privacy (SP)*, pages 3607–3626, Los Alamitos, CA, USA, May 2026. IEEE Computer Society.
- [13] Reiner Sailer, Xiaolan Zhang, Trent Jaeger, and Leendert Van Doorn. Design and implementation of a tcg-based integrity measurement architecture. In *USENIX Security symposium*, volume 13, pages 223–238, 2004.
- [14] Alon Shakevsky, Eyal Ronen, and Avishai Wool. Trust dies in darkness: Shedding light on samsung’s TrustZone keymaster design. In *31st USENIX Security Symposium (USENIX Security 22)*, pages 251–268, Boston, MA, August 2022. USENIX Association.
- [15] Jianxiong Shao, Yu Qin, and Dengguo Feng. Formal analysis of hmac authorisation in the tpm2.0 specification. *IET Information Security*, 12(2):133–140, 2018.
- [16] Torben Woltjen, Michelle Jakobi, Michael Eckel, Janik Gorbracht, and Richard Sethmann. Trustworthy secure

and measured boot on a raspberry pi 4. In *European Conference on Cyber Warfare and Security*, pages 906–914. Academic Conferences International Limited, 2026.